

Task 4.3D

Tests

Valid Tests

I first tested these values as a valid baseline. It works as expected.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/client/showForm

Name:

Age:

Email:

Message

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Bob, please, run for 30 min

Your message "This is a custom message to the coach!" was received and you will be contacted via your email: bob@domain.com for further information.

To ensure that the message allows special characters like !@#*,. The tested message contains these special characters with some common punctuation, keeping the other fields valid. It worked as expected and the submission was accepted. This confirms that the regex whitelist permits !@#* along side letters, digits and basic punctuation.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/client/showForm

Name:

Age:

Email:

Message

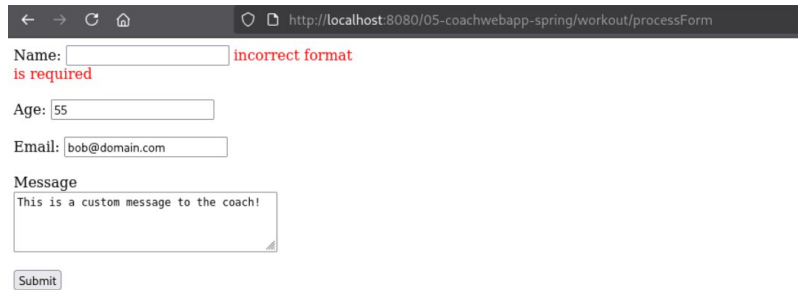
← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Bob, please, run for 30 min

Your message "Great session today. Add #strength_training, rest @ 8pm - 5 stars * keep it up!" was received and you will be contacted via your email: bob@domain.com for further information.

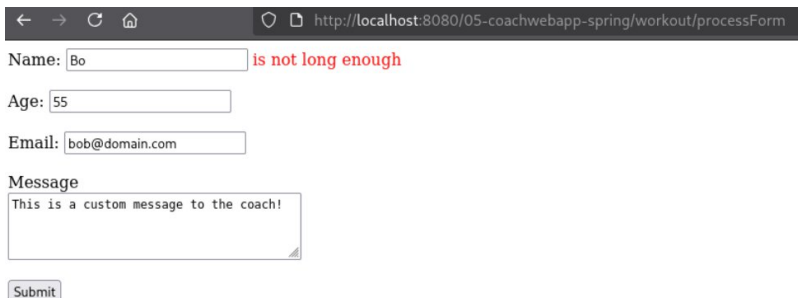
Invalid Names

To test that the name field rejects empty input, I tested with Name not set to anything/blank. It didn't work and the server returned the form again with a validation error, because `@NotNull` rejects the missing value.



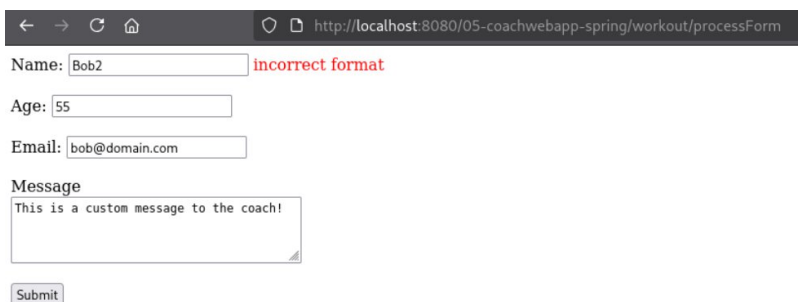
A screenshot of a web browser at the URL `http://localhost:8080/05-coachwebapp-spring/workout/processForm`. The form contains fields for Name, Age, Email, and a Message. The Name field is empty, and a red error message "incorrect format is required" is displayed next to it. The Age field contains "55", the Email field contains "bob@domain.com", and the Message field contains "This is a custom message to the coach!". A "Submit" button is at the bottom.

To test that the name field restricts the submissions to a minimum length, I tested with Name set to Bo. The server rejected it because `@Size(min = 3)` requires at least 3 characters and it shows a meaningful error message.



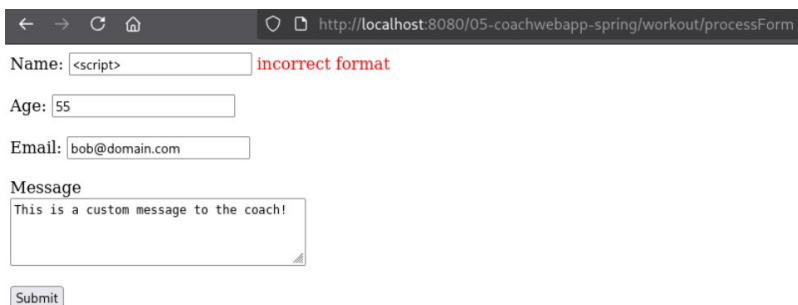
A screenshot of a web browser at the URL `http://localhost:8080/05-coachwebapp-spring/workout/processForm`. The form contains fields for Name, Age, Email, and a Message. The Name field contains "Bo", and a red error message "is not long enough" is displayed next to it. The Age field contains "55", the Email field contains "bob@domain.com", and the Message field contains "This is a custom message to the coach!". A "Submit" button is at the bottom.

To test that the name field rejects non alphabetical characters, I tested with Name set to Bob2. The server rejected it because the `@Pattern` regex `[a-zA-Z]+` only permits letters and it showed a meaningful error message suggesting it has something to do with the format.



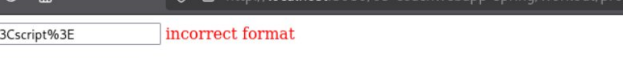
A screenshot of a web browser at the URL `http://localhost:8080/05-coachwebapp-spring/workout/processForm`. The form contains fields for Name, Age, Email, and a Message. The Name field contains "Bob2", and a red error message "incorrect format" is displayed next to it. The Age field contains "55", the Email field contains "bob@domain.com", and the Message field contains "This is a custom message to the coach!". A "Submit" button is at the bottom.

Similarly, characters like `<` and `>` was also rejected because they all fall outside of `[a-zA-Z]+`.



A screenshot of a web browser at the URL `http://localhost:8080/05-coachwebapp-spring/workout/processForm`. The form contains fields for Name, Age, Email, and a Message. The Name field contains "`<script>`", and a red error message "incorrect format" is displayed next to it. The Age field contains "55", the Email field contains "bob@domain.com", and the Message field contains "This is a custom message to the coach!". A "Submit" button is at the bottom.

I attempted using some URL encoding for < and >. As it has characters that falls outside the whitelist regex, this gets rejected too.



The screenshot shows a web browser window with the address bar displaying `http://localhost:8080/05-coachwebapp-spring/workout/processForm`. The page contains a form with the following fields:

- Name:** A text input field containing the value `%3Cscript%3E`. To the right of the field, the text `incorrect format` is displayed in red.
- Age:** A text input field containing the value `55`.
- Email:** A text input field containing the value `bob@domain.com`.
- Message:** A text area containing the value `This is a custom message to the coach!`.

At the bottom of the form, there is a **Submit** button.

Invalid Emails

To test that the email field enforces a .com domain, I tested with Email set to bob@domain.org. The server rejected it because the regex `^[a-zA-Z0-9. ]+@[a-zA-Z0-9.]+\.$` only accepts a .com suffix.



← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email: must be a valid email address, e.g. name@domain.com

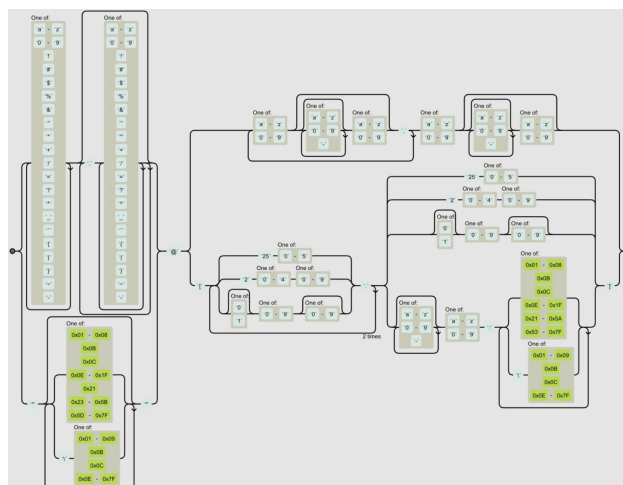
Message

However, using regular expressions to validate emails is considered bad practice^{[1][2]}. Proper standard compliant email regexes are much more complicated than it seems.

A simple regex like mine can reject valid emails or accept invalid ones, while the fully RFC822 compliant regex is just massive and difficult to maintain. It's recommended to use email parsers that are already provided by a language or a framework.

A much more efficient regex is the RTC5322 compliant version^[3]. Below is that regex with it's railroad diagram.

```
(?:[a-z0-9!#$%&'*/+=?^_`{|}~]+(?:\.[a-z0-9!#$%&'*/+=?^_`{|}~]+)*)"(?:[x01-x08\x0b\x0c\x0e-lx1fx21x23-lx5b\x5d-lx7f]|\[x01-lx09\x0b\x0c\x0e-lx7f])")@(?:\.(?:[a-z0-9](?:[a-z0-9]*[a-z0-9])?.)+[a-z0-9](?:[a-z0-9]*[a-z0-9])?)\[(?:\.(?:25[0-5]|2[0-4][0-9]|[01]?[0-9][0-9]?)\.){3}(?:25[0-5]|2[0-4][0-9]|[01]?[0-9][0-9]?|[a-z0-9]*[a-z0-9](?:[x01-x08\x0b\x0c\x0e-lx1fx21-lx5a\x53-lx7f]|\[x01-lx09\x0b\x0c\x0e-lx7f])+)]\]
```



The web servers code can be updated by simply replacing my regex with this value. However, for the rest of this task, I will be using my own regex. But I thought it would be great to mention the correct way of doing things too.

To test whether the email field requires an @ symbol, I used bobdomain.com as the email address. The frontend initially blocked the submission because `type="email"` detected it as invalid. Because of this, I later sent the request using curl, which confirmed that the server also rejected it because the regex requires an @ between the local part and domain.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email: must be a valid email address, e.g. name@domain.com

Message:

Please enter an email address.

This is

```
curl -s http://localhost:8080/05-coachwebapp-spring/workout/processForm -d "name=Bob&age=55&email=bobdomain.com&message=hello"
<!DOCTYPE html>
<html>
<head>
<title>Client Registration Form</title>
<style>
.error {color:red}
</style>
</head>
<body>
<form id="client" action="/05-coachwebapp-spring/workout/processForm" method="post">
  Name: <input id="name" name="name" type="text" value="Bob"/>
  <br><br>
  Age: <input id="age" name="age" type="text" value="55"/>
  <br><br>
  Email: <input id="email" name="email" title="Enter a valid email address, e.g. name@domain.com" pattern="[a-zA-Z0-9_]+@[a-zA-Z0-9-]+\.\com" type="email" required="required" value="bobdomain.com"/>
  <span id="email.errors" class="error">must be a valid email address, e.g. name@domain.com</span>
  <br><br>
  Message <br>
  <textarea id="message" name="message" maxlength="200" required="required" rows="4" cols="40">
hello</textarea>
</body>
</html>
```

To test whether the email field blocks script injection, I used <script>@domain.com as the email address. The server rejected it because < and > are not included in the allowed character set.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email: must be a valid email address, e.g. name@domain.com

Message:

Please enter an email address.

This is

```
curl -s http://localhost:8080/05-coachwebapp-spring/workout/processForm -d "name=Bob&age=55&email=<script>@domain.com&message=hello"
<!DOCTYPE html>
<html>
<head>
<title>Client Registration Form</title>
<style>
.error {color:red}
</style>
</head>
<body>
<form id="client" action="/05-coachwebapp-spring/workout/processForm" method="post">
  Name: <input id="name" name="name" type="text" value="Bob"/>
  <br><br>
  Age: <input id="age" name="age" type="text" value="55"/>
  <br><br>
  Email: <input id="email" name="email" title="Enter a valid email address, e.g. name@domain.com" pattern="[a-zA-Z0-9_]+@[a-zA-Z0-9-]+\.\com" type="email" required="required" value="<script>@domain.com"/>
  <span id="email.errors" class="error">must be a valid email address, e.g. name@domain.com</span>
  <br><br>
  Message <br>
  <textarea id="message" name="message" maxlength="200" required="required" rows="4" cols="40">
hello</textarea>
</body>
</html>
```

I attempted to escape the filters by encoding < and > and it failed and expected too.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email: must be a valid email address, e.g. name@domain.com

Message

To test whether the email field blocks stray special characters, I used bob@domain.com;calc as the email address. The server rejected it because the regex does not allow the ; character.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email: must be a valid email address, e.g. name@domain.com

Message

```
curl -s http://localhost:8080/05-coachwebapp-spring/workout/processForm -d "name=bobage55email=bob@domain.com;calcmessage=hello"

<!DOCTYPE html>
<html>
<head>
<title>Client Registration Form</title>
<style>
.error {color:red}
</style>
</head>
<body>
<form id="client" action="/05-coachwebapp-spring/workout/processForm" method="post">
  Name: <input id="name" name="name" type="text" value="Bob" />
  <br><br>
  Age: <input id="age" name="age" type="text" value="55" />
  <br><br>
  Email: <input id="email" name="email" title="Enter a valid email address, e.g. name@domain.com" pattern="[a-zA-Z0-9_!@&quot;#%&#39;*~&#124;+&#60;&#62;=&#63;~&#96;.-]+@([a-zA-Z0-9-]+)\.com" type="email" required="required" value="bob@domain.com;calc" />
  <span id="email.errors" class="error">must be a valid email address, e.g. name@domain.com</span>
  <br><br>
  Message <br>
  <input id="message" name="message" type="text" value="This is" />
  <br><br>
  <input type="button" value="Submit" />
</form>
</body>
</html>
```

To test whether the email field is required, I left it blank. The server rejected the submission because @NotNull requires the field to have a value.

← → ↻ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email: must be a valid email address, e.g. name@domain.com

Message

```

$ curl -s http://localhost:8080/05-coachwebapp-spring/workout/processForm -d "name=Bob&age=55&email=&message=hello"
<!DOCTYPE html>
<html>
<head>
<title>Client Registration Form</title>
<style>
.error {color:red}
</style>
</head>
<body>
<form id="client" action="/05-coachwebapp-spring/workout/processForm" method="post">
  Name: <input id="name" name="name" type="text" value="Bob" />
  <br><br>
  Age: <input id="age" name="age" type="text" value="55" />
  <br><br>
  Email: <input id="email" name="email" title="Enter a valid email address, e.g. name@domain.com" pattern="[a-zA-Z0-9_]+@[a-zA-Z0-9-]+\." type="email" required="required" value="" />
  <span id="email.errors" class="error">must be a valid email address, e.g. name@domain.com</span>
  <br><br>
  Message <br>
  <textarea id="message" name="message" maxlength="200" required="required" rows="4" cols="40">
    hello/test
  </textarea>
  <input type="submit" value="Submit" />
</form>
</body>
</html>

```

Invalid Messages

To test whether the message field blocks a classic XSS payload, I used `<script>alert('XSS')</script>` as the message. The server rejected it because `<`, `>`, and `'` are not included in the allowed character set `[a-zA-Z0-9_.,!@#*_-]`.

← → ↺ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email:

Message

 contains unsupported characters

To test whether the message field blocks an event-handler-based XSS payload, I used `<img src=x onerror=alert(1)>` as the message. The server rejected it because `<`, `>`, and `=` are not included in the allowed character set.

← → ↺ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

Age:

Email:

Message

 contains unsupported characters

To test whether the message field blocks SQL-injection-style input, I used `' ; DROP TABLE clients; --` as the message. The server rejected it because `'` and `;` are not included in the allowed character set.

← → ↺ 🏠 http://localhost:8080/05-coachwebapp-spring/workout/processForm

Name:

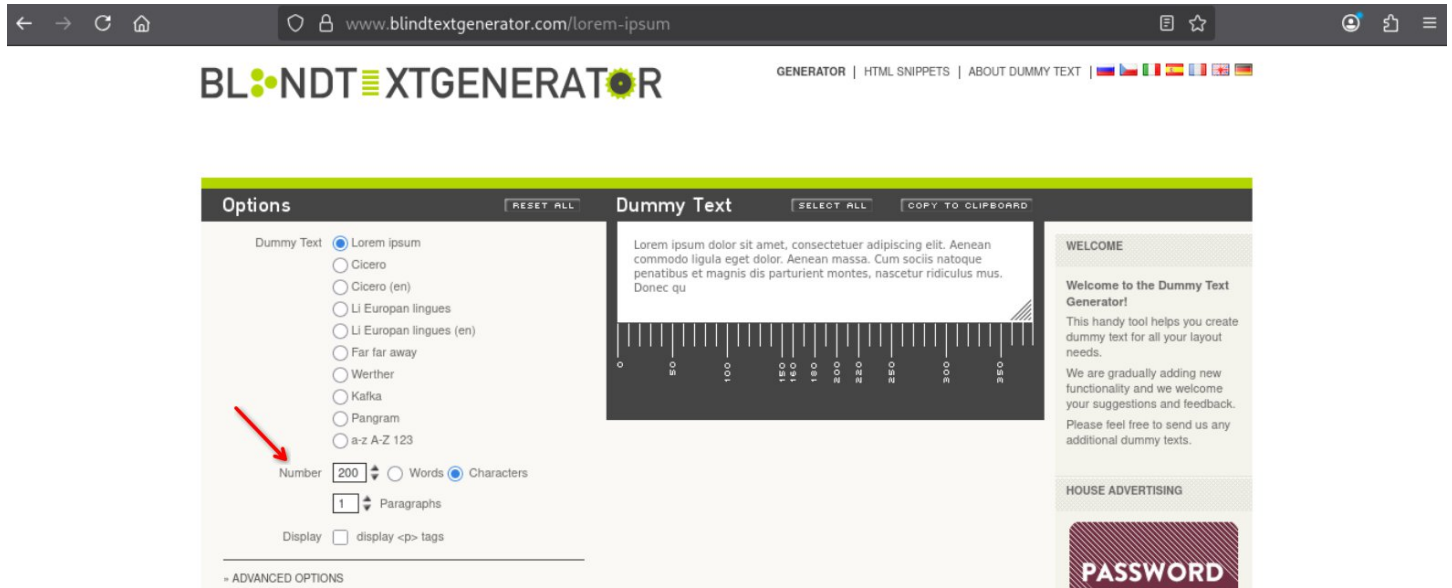
Age:

Email:

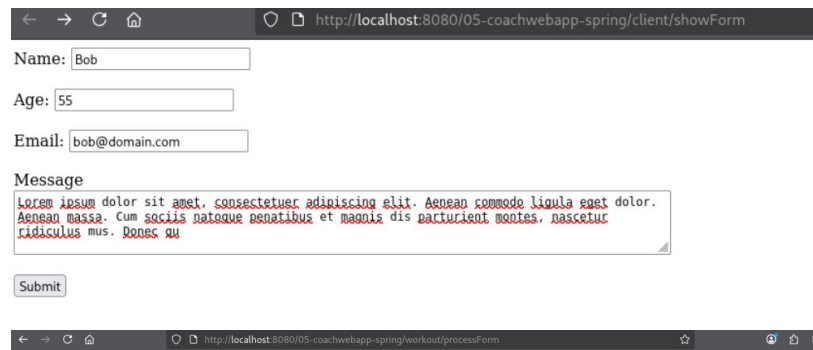
Message

 contains unsupported characters

To test whether the message field accepts the maximum allowed length, I used a message containing exactly 200 characters.



The form submitted successfully, confirming that messages with up to 200 characters are accepted.



The frontend prevents users from entering more than 200 characters in the text area. Because of this, I used curl to send a message containing 201 characters directly to the server.



The frontend also prevents users from submitting an empty message.

However, this validation can be bypassed using curl, and the server accepts the empty value.

This happens because `@NotNull` only checks whether the value is null. An empty string is still a value, so it passes the validation. This can be fixed by replacing `@NotNull` with `@NotEmpty`, which rejects both null and empty values.

To confirm this further, I sent another curl request without including the message field. The server rejected the request because the missing value was treated as null, which triggered the @NotNull validation.

```

kali@kali:~$ curl -s http://localhost:8080/05-coachwebapp-spring/workout/processForm -d "name=Bob&age=bob@domain.com"
<!DOCTYPE html>
<html>
<head>
<title>Client Registration Form</title>

<style>
.error {color:red}
</style>

</head>
<body>

<form id="client" action="/05-coachwebapp-spring/workout/processForm" method="post">
  Name: <input id="name" name="name" type="text" value="Bob"/>

  <br><br>
  Age: <input id="age" name="age" type="text" value="55"/>

  <br><br>
  Email: <input id="email" name="email" title="Enter a valid email address, e.g. name@domain.com" pattern="[a-zA-Z0-9_]+@[a-zA-Z0-9-]+\.\com" type="email" required="required" value="bob@domain.com"/>

  <br><br>
  Message <br>
  <textarea id="message" name="message" maxlength="200" required="required" rows="4" cols="40">

  <span id="message.errors" class="error">is required</span>

  <br><br>

```


Source Code

java/edu/deakin/sit218/coachwebapp/Client.java

Project Explorer x

01-coachwebapp [secure-coding-course-sources main]

02-vul-coachwebapp [secure-coding-course-sources main]

05-coachwebapp-spring [secure-coding-course-sources main]

Deployment Descriptor: 05-coachwebapp-spring

JAX-WS Web Services

Java Resources

Referenced Libraries

src

main

java

edu

deakin

sit218

coachwebapp

Client.java

ClientController.java

CoachController.java

webapp

META-INF

WEB-INF

lib

view

client-form.jsp

workout.jsp

spring-configuration.xml

web.xml

index.jsp

07-coachwebapp-spring-hibernate [secure-coding-course-sources main]

08-session-management [secure-coding-course-sources main]

attackerpage

coachweb-springapp

Error-logging

Error-logging-updated

examgeneration

examgeneration-extended

examgeneration-updated

harvest-coachweb-springapp

Client.java x

index.jsp

client-form.jsp

workout.jsp

ClientController.java

CoachController.java

```
1 package edu.deakin.sit218.coachwebapp;
2
3 import javax.validation.constraints.Max;
4 //import org.hibernate.validator.constraints
5
6 public class Client {
7
8     // Uncomment the lines below if you want to validate the age too
9     // but it didn't seem like this was a requirement of this task
10    // @NotNull(message = "is required")
11    // @Size(min = 3, message = "is not long enough")
12    // @Pattern(regexp = "[a-zA-Z]*", message = "incorrect format")
13    protected String name;
14
15    // @NotNull(message = "is required")
16    // @NotEmpty(message = "is required")
17    // @Size(max = 200, message = "must not exceed 200 characters")
18    // @Pattern(regexp = "[a-zA-Z0-9.,!?@#_-]*", message = "contains unsupported characters")
19    protected String message;
20
21    public String getName() {
22        return name;
23    }
24
25    public void setName(String name) {
26        this.name = name;
27    }
28
29    public int getAge() {
30        return age;
31    }
32
33    public void setAge(int age) {
34        this.age = age;
35    }
36
37    public String getEmail() {
38        return email;
39    }
40
41    public void setEmail(String email) {
42        this.email = email;
43    }
44
45    public String getMessage() {
46        return message;
47    }
48
49    public void setMessage(String message) {
50        this.message = message;
51    }
52
53 }
54
55 }
```

java/edu/deakin/sit218/coachwebapp/ClientController.java

Project Explorer x

01-coachwebapp [secure-coding-course-sources main]

02-vul-coachwebapp [secure-coding-course-sources main]

05-coachwebapp-spring [secure-coding-course-sources main]

Deployment Descriptor: 05-coachwebapp-spring

JAX-WS Web Services

Java Resources

Referenced Libraries

src

main

java

edu

deakin

sit218

coachwebapp

Client.java

ClientController.java

CoachController.java

webapp

META-INF

WEB-INF

lib

view

client-form.jsp

workout.jsp

spring-configuration.xml

web.xml

index.jsp

07-coachwebapp-spring-hibernate [secure-coding-course-sources main]

08-session-management [secure-coding-course-sources main]

attackerpage

coachweb-springapp

Error-logging

Error-logging-updated

examgeneration

examgeneration-extended

examgeneration-updated

harvest-coachweb-springapp

Client.java

index.jsp

client-form.jsp

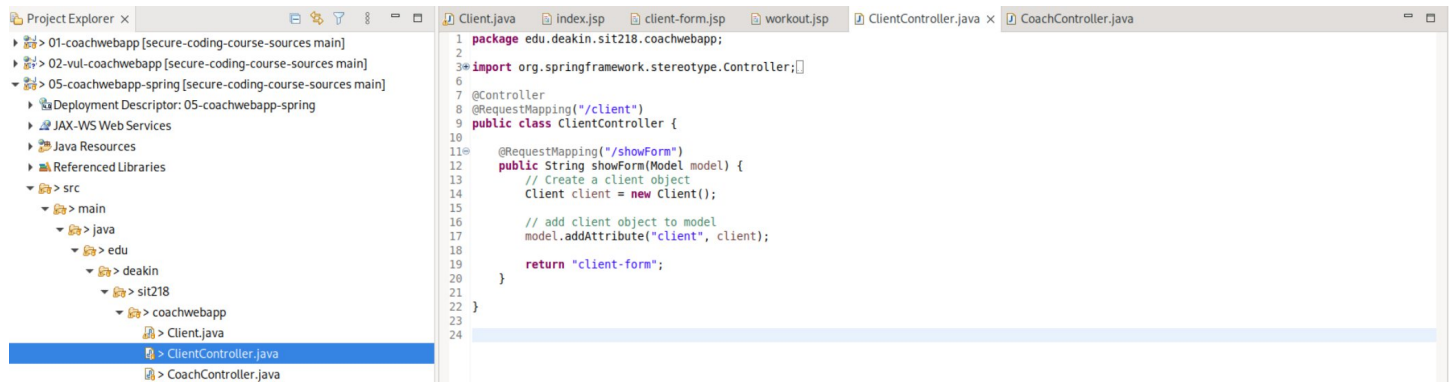
workout.jsp

ClientController.java

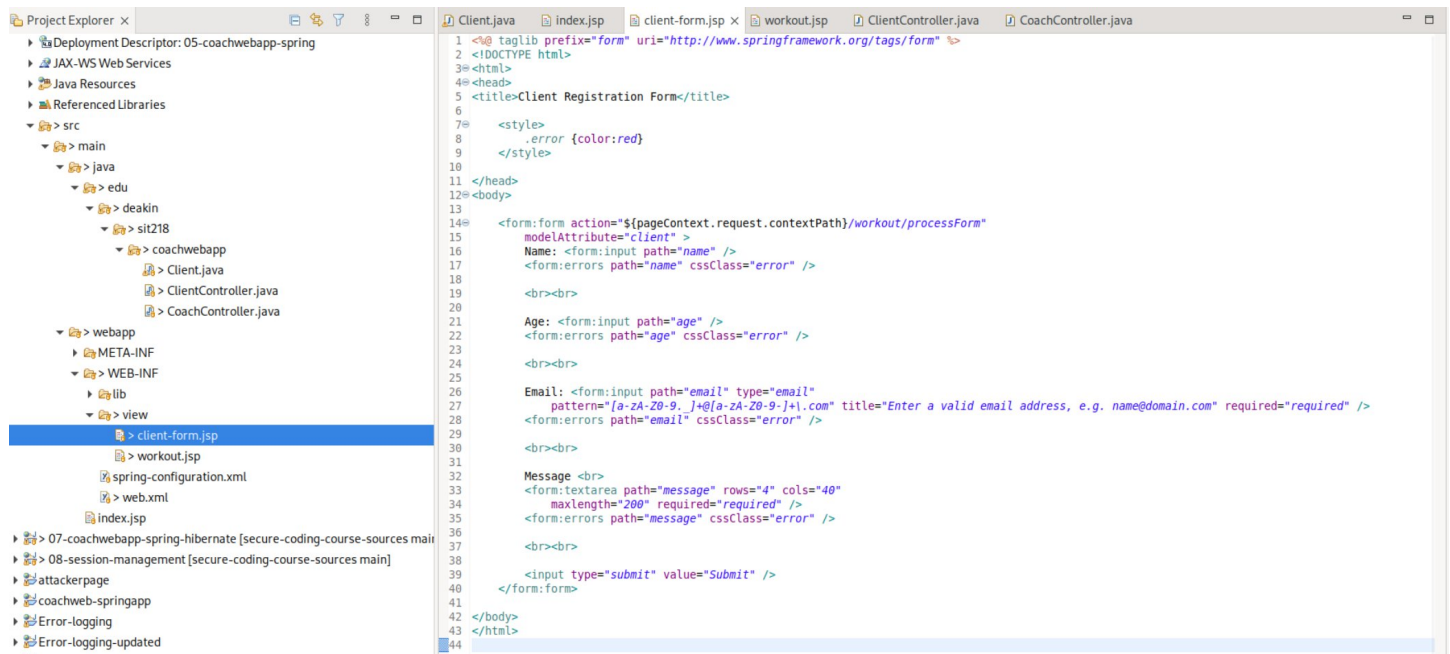
CoachController.java x

```
1 package edu.deakin.sit218.coachwebapp;
2
3 import javax.validation.Valid;
4
5 import org.springframework.stereotype.Controller;
6 import org.springframework.ui.Model;
7 import org.springframework.validation.BindingResult;
8 import org.springframework.web.bind.annotation.ModelAttribute;
9 import org.springframework.web.bind.annotation.RequestMapping;
10
11 @Controller
12 @RequestMapping("/workout")
13 public class CoachController {
14
15     @RequestMapping("/processForm")
16     public String workout(
17         @Valid @ModelAttribute("client") Client client,
18         BindingResult validationErrors, Model model
19     ) {
20         //Input validation
21         if (validationErrors.hasErrors())
22             return "client-form";
23         throw new IllegalArgumentException("Invalid Input");
24
25         //Logic when there is no error
26         else if (client.age < 40) {
27             model.addAttribute("message", "Hey, " + client.getName() +
28                 " you are still too young, no need to work out!");
29         }
30
31         else {
32             model.addAttribute("message", client.getName() +
33                 ", please, run for 30 min");
34         }
35
36         model.addAttribute("email", client.getEmail());
37         model.addAttribute("userMessage", client.getMessage());
38         return "workout";
39     }
40
41 }
42 }
```

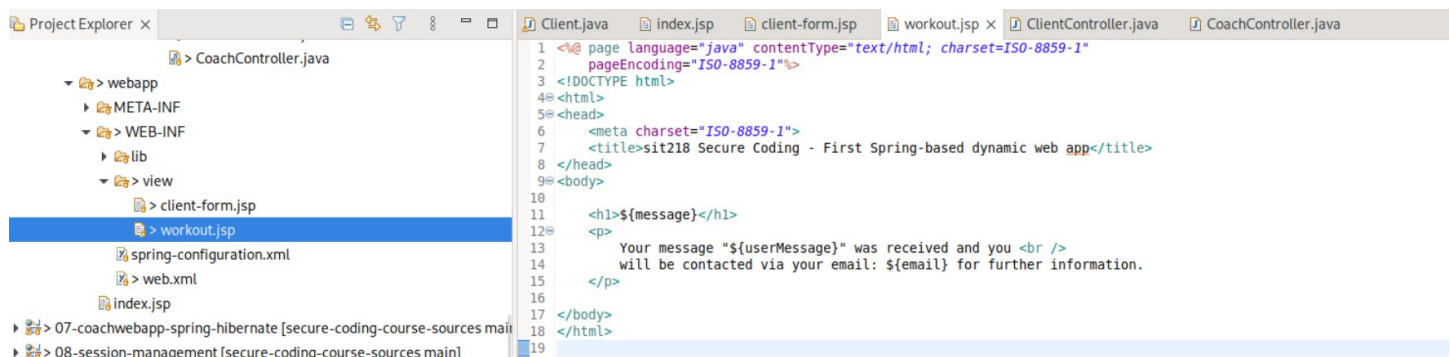
java/edu/deakin/sit218/coachwebapp/CoachController.java



webapp/WEB-INF/view/client-form.jsp



webapp/WEB-INF/view/workout.jsp



webapp/index.jsp



References

- [1] Stack Overflow, "How can I validate an email address using a regular expression?," Answer 201378. [Online]. Available: <https://stackoverflow.com/a/201378/14819138>. [Accessed: Aug. 24, 2026].
- [2] P. Warren, "Mail::RFC822::Address." [Online]. Available: <https://pdw.ex-parrot.com/Mail-RFC822-Address.html>. [Accessed: Aug. 24, 2026].
- [3] EmailRegex.com, "Email Address Regular Expression That 99.99% Works." [Online]. Available: <https://emailregex.com/>. [Accessed: Aug. 24, 2026].